



DPDP Compliance Checklist for CA Firms

Is Your Practice Ready for India's Data Protection Law?

The Digital Personal Data Protection (DPDP) Act, 2023 is now enforceable. CA firms are classified as Data Fiduciaries — meaning you're legally responsible for every piece of client data you collect, store, and process.

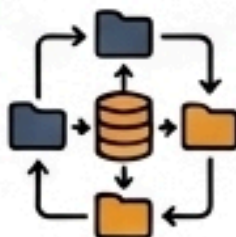
Non-compliance penalties: Up to ₹250 crore
for general violations | ₹200 crore for breach notification failures

Phase 1: Data Discovery (Complete by Week 1-2)



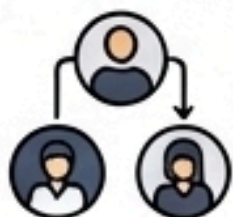
Conduct a complete data inventory

List every type of personal data you collect: PAN cards, Aadhaar, ITR documents, bank statements, GST records, audit files, client emails, WhatsApp messages



Map data flows

Document where data enters (email, WhatsApp, Google Forms, physical docs), where it's stored (Google Drive, Tally, laptops, phones), and who has access



Deciding Processing

Identify your role

Are you a Data Fiduciary (you decide why/how data is processed) or Data Processor (you process on behalf of another entity)? Most CA firms are Fiduciaries



Phase 2: Legal Foundations

(Complete by Week 3-4)

- ☐  **Update engagement letters**
Add DPDP-compliant data clauses: purpose of collection, retention period, consent statement, client rights
- ☐  **Create a Privacy Notice**
Publish on your website and share with clients. Must include: what data you collect, why, how long you keep it, who you share it with, and how clients can exercise their rights
- ☐  **Obtain valid consent**
Consent must be free, specific, informed, and unconditional. "Submitting this form" counts – but only if your notice is clear



Stop using WhatsApp for documents



switch to



Phase 3: Data Security (Complete by Week 5-8)

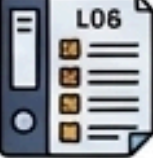
- ☐ **Implement encryption**
 Encrypt data at rest (storage) and in transit (email, file transfers). Use tools that support end-to-end encryption
- ☐ **Set up access controls**
 Only authorized staff should access client data. Use role-based permissions in Tally, Drive, and your document portal
- ☐ **Enable Multi-Factor Authentication (MFA)**
 Add 2FA to all accounts handling client data: email, cloud storage, accounting software
- ☐ **Conduct a security audit**
 Review: Are laptops password-protected? Are files shared via public links? Are backups encrypted?

Phase 4: Rights & Breach Readiness

(Complete by Week 9-12)

- ☐  **Establish a process for Data Principal Rights**
Clients can request: access to their data, corrections, deletion, or withdrawal of consent. You must respond within the timeline set by the Data Protection Board
- ☐  **Create a breach notification plan**
If client data is leaked/hacked, you must notify the Data Protection Board within 72 hours 
- ☐  **Draft a breach notification template**
Pre-write the email/letter format so you're not scrambling during an incident (see our separate template)
- ☐  **Audit third-party tools**
Tally, Zoho, Google Drive, payment gateways – ensure each has a Data Processing Agreement (OPA) stating their DPDP responsibilities
  

Phase 5: Training & Documentation (Ongoing)

- ☐  **Train your team**
All staff handling client data must understand: consent, data security, breach protocols, client rights. Conduct annual refresher training
- ☐  **Designate a Data Protection Officer (if SDF)**
If you're a "Significant Data Fiduciary" (high volume of sensitive data), you must appoint a DPO. Most small CA firms won't qualify, but large practices might
- ☐  **Maintain compliance records**
Keep logs of: consent obtained, data access requests, security audits, breach drills, DPA agreements. These prove compliance during audits

✓ Automate 8 items on this list with **VERIFID** FORMS

- ✓ Encrypted document collection
- ✓ Built-in consent capture
- ✓ Comprehensive audit trails
- ✓ Data inventory and mapping
- ✓ Privacy Notice generation
- ✓ Multi-Factor Authentication (MFA) enforcement
- ✓ Role-based access controls
- ✓ Breach notification preparation

[Start Free → verifidforms.com]